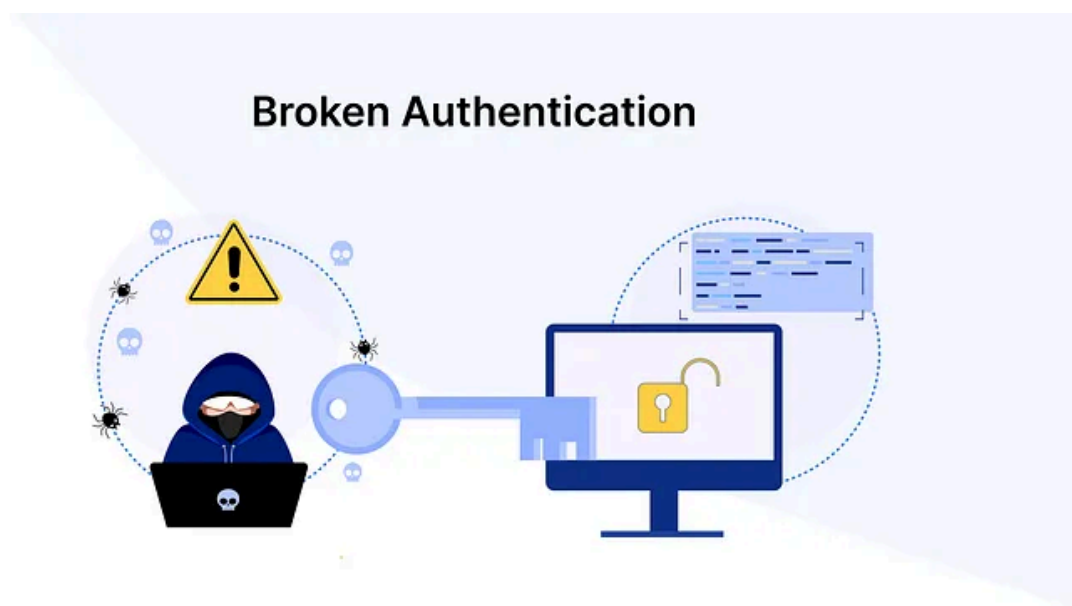


Authentication

1. Khái Niệm Xác Thực (Authentication)

Xác thực là quá trình chứng minh rằng người dùng, dịch vụ, hoặc thiết bị là đúng như những gì họ khai báo, tức là hệ thống kiểm tra danh tính của đối tượng trước khi cấp quyền truy cập. Đây là bước đầu tiên và cốt lõi trong việc bảo vệ tài nguyên số.



1.1. Các phương pháp xác thực chính

Xác thực thường được chia thành ba yếu tố chính, được gọi là "something you know, something you have, and something you are":

- **Something you know (Thông tin mà bạn biết):**
 - a. Đây là loại xác thực phổ biến nhất, bao gồm:
 - i. **Mật khẩu:** Chuỗi ký tự mà chỉ người dùng biết.
 - ii. **Câu hỏi bảo mật:** Được sử dụng khi quên mật khẩu, nhưng dễ bị đoán nếu câu hỏi quá dễ.



- iii. **PIN:** Một chuỗi số ngắn mà người dùng thiết lập.
- b. **Nhược điểm:** Yếu tố này dễ bị tổn thương trước các cuộc tấn công brute-force và phishing. Nếu mật khẩu yếu hoặc được tái sử dụng, kẻ tấn công có thể dễ dàng bẻ khóa.
- **Something you have (Thiết bị hoặc vật phẩm mà bạn sở hữu):**
 - a. Các yếu tố xác thực thuộc nhóm này đòi hỏi người dùng phải sở hữu một thiết bị cụ thể, ví dụ:
 - i. **Token bảo mật:** Thiết bị phần cứng cung cấp mã xác thực, thường được dùng trong môi trường doanh nghiệp.
 - ii. **Smartphone:** Điện thoại có thể nhận mã OTP qua SMS hoặc thông qua ứng dụng xác thực như Google Authenticator.
 - iii. **Thẻ ID hoặc USB:** Được cắm vào máy tính để xác thực.
 - b. **Nhược điểm:** Các phương thức dựa trên thiết bị có thể bị tấn công nếu thiết bị bị đánh cắp hoặc sao chép. Ví dụ, tấn công SIM swap có thể cho phép kẻ tấn công truy cập vào mã OTP gửi qua SMS.
- **Something you are (Thông tin sinh trắc học):**
 - a. **Sinh trắc học:** Là phương pháp sử dụng đặc điểm vật lý của người dùng để xác thực, như:
 - i. **Vân tay:** Được sử dụng phổ biến trên các thiết bị di động.
 - ii. **Quét khuôn mặt:** Dùng camera để nhận diện khuôn mặt.
 - iii. **Móng mắt:** Được sử dụng trong các hệ thống bảo mật cao cấp.
 - b. **Nhược điểm:** Dữ liệu sinh trắc học nếu bị đánh cắp rất khó để thay đổi, và công nghệ sinh trắc học có thể bị đánh lừa bằng cách làm giả.

1.2. Các hình thức xác thực phức tạp hơn

- **Xác thực đa yếu tố (MFA - Multi-Factor Authentication):**
 - Là phương pháp kết hợp ít nhất hai yếu tố xác thực khác nhau, ví dụ sử dụng cả mật khẩu và mã OTP từ điện thoại.
 - **Ưu điểm:** Tăng cường tính bảo mật vì kẻ tấn công phải phá vỡ nhiều lớp bảo vệ.



- **Nhược điểm:** Phức tạp cho người dùng và có thể gây bất tiện.
- **Xác thực liên phiên (SSO - Single Sign-On):**
 - Cho phép người dùng đăng nhập một lần và truy cập nhiều ứng dụng khác nhau.
 - **Ưu điểm:** Đơn giản hóa trải nghiệm người dùng.
 - **Nhược điểm:** Nếu tài khoản SSO bị xâm nhập, tất cả các dịch vụ liên quan đều có thể bị tấn công.

1.3. Tầm quan trọng của xác thực trong bảo mật

- Xác thực là lớp bảo mật đầu tiên chống lại các cuộc tấn công mạng. Nếu xác thực bị xâm phạm, kẻ tấn công có thể truy cập toàn bộ tài khoản và dữ liệu của người dùng.
- Do đó, việc triển khai cơ chế xác thực phải được thực hiện cẩn thận, kết hợp nhiều lớp bảo vệ và tuân thủ các nguyên tắc an toàn mạng.

2. Sự khác biệt giữa xác thực và ủy quyền (Authorization)

- **Xác thực:** Xác minh người dùng là ai.
- **Ủy quyền:** Xác định người dùng có quyền làm gì.

3. Cách thức tấn công phổ biến (brute-force)

a. Brute-Force Tối giản

- **Mô tả:** Kẻ tấn công thử tất cả các kết hợp của ký tự cho đến khi tìm ra mật khẩu đúng. Được thực hiện với một danh sách các mật khẩu phổ biến.
- **Ví dụ thực tế:** Một trang web không có giới hạn số lần thử mật khẩu. Kẻ tấn công sử dụng một chương trình để thử tất cả các mật khẩu từ một danh sách như "123456", "password", "letmein".

b. Brute-Force Thông minh



- **Mô tả:** Kẻ tấn công kết hợp thông tin có sẵn về người dùng để tạo ra các mật khẩu có thể có. Ví dụ: sử dụng tên, ngày sinh hoặc thông tin cá nhân.
- **Ví dụ thực tế:** Nếu tên người dùng là "JohnDoe" và ngày sinh là "1985", kẻ tấn công có thể thử các mật khẩu như "John1985", "Doe1985".

c. Brute-Force Thời gian

- **Mô tả:** Kẻ tấn công cố gắng khai thác thời gian phản hồi từ hệ thống để biết được mật khẩu đúng. Nếu hệ thống phản hồi nhanh hơn với mật khẩu đúng, kẻ tấn công có thể dự đoán được điều này.
- **Ví dụ thực tế:** Một trang web phản hồi nhanh hơn khi mật khẩu gần đúng, cho phép kẻ tấn công điều chỉnh các thử nghiệm tiếp theo dựa trên thời gian phản hồi.

d. Tấn công Hybrid

- **Mô tả:** Kẻ tấn công sử dụng phương pháp kết hợp giữa brute-force và thông tin xã hội. Họ có thể sử dụng một danh sách mật khẩu phổ biến nhưng thêm thông tin cá nhân.
- **Ví dụ thực tế:** Kẻ tấn công lấy danh sách mật khẩu phổ biến và thêm tên của người dùng vào đầu hoặc cuối, như "JohnDoe123" hoặc "123JohnDoe".

4. Các cách tấn công trong xác thực

a. Tấn công Phishing

- **Mô tả:** Kẻ tấn công tạo ra một trang web giả mạo để lừa người dùng cung cấp thông tin đăng nhập.
- **Nguy cơ:** Thông tin đăng nhập bị đánh cắp và kẻ tấn công có thể truy cập tài khoản của người dùng.
- **Ví dụ:** Một email giả mạo yêu cầu người dùng đăng nhập để xác nhận thông tin tài khoản, dẫn đến một trang web giả giống như trang chính thức.



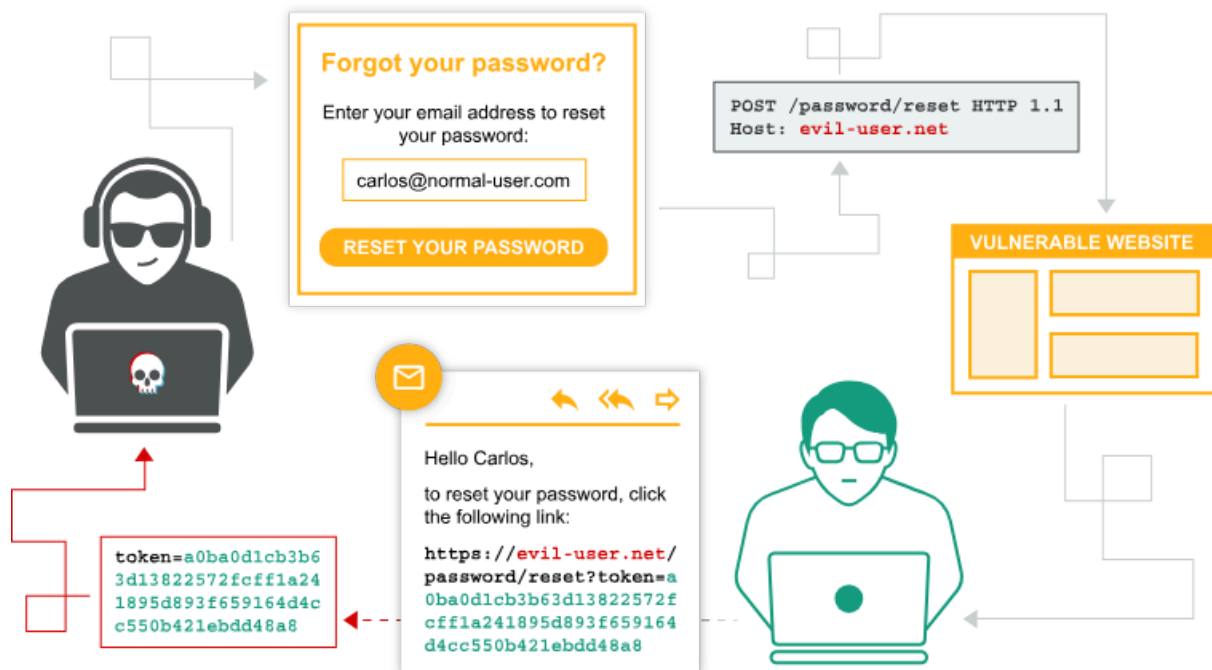
b. SIM Swapping

- **Mô tả:** Kẻ tấn công lừa đảo nhà cung cấp dịch vụ di động để chuyển số điện thoại của nạn nhân sang SIM của họ.
- **Nguy cơ:** Kẻ tấn công nhận được mã xác thực SMS và có thể truy cập vào tài khoản của nạn nhân.
- **Ví dụ:** Kẻ tấn công gọi đến nhà cung cấp dịch vụ, giả mạo nạn nhân và yêu cầu chuyển số điện thoại của nạn nhân sang SIM mới.

c. Tấn công Man-in-the-Middle (MitM)

- **Mô tả:** Kẻ tấn công chặn và thao tác thông tin giữa người dùng và máy chủ.
- **Nguy cơ:** Kẻ tấn công có thể đánh cắp thông tin đăng nhập và mã xác thực.

- **Ví dụ:** Sử dụng một điểm truy cập Wi-Fi công cộng để chặn dữ liệu giữa người dùng và trang web, thu thập thông tin nhạy cảm.



5. Phòng ngừa tấn công

- **Chú ý đến thông tin người dùng:** Không tiết lộ thông tin tài khoản qua HTTP không mã hóa.
- **Không phụ thuộc vào người dùng:** Thiết lập chính sách mật khẩu mạnh và kiểm tra độ mạnh mật khẩu.
- **Chống lại việc xác định tên người dùng:** Sử dụng thông báo lỗi chung cho mọi trường hợp.
- **Bảo vệ chống tấn công brute-force:** Áp dụng giới hạn tốc độ và CAPTCHA.
- **Kiểm tra logic xác thực:** Đảm bảo không có lỗi logic cho phép bỏ qua xác thực.
- **Chức năng bổ sung:** Đảm bảo các trang đổi mật khẩu và phục hồi mật khẩu cũng được bảo mật.
- **Thực hiện đa yếu tố xác thực đúng cách:** Sử dụng thiết bị hoặc ứng dụng chuyên dụng, không chỉ dựa vào SMS hoặc email.



6. Các phương pháp an toàn

- **Giới hạn số lần đăng nhập:** Đặt giới hạn số lần thử mật khẩu, khóa tài khoản tạm thời sau một số lần thử không thành công.
- **Xác thực đa yếu tố mạnh mẽ:** Sử dụng ứng dụng xác thực (như Google Authenticator) thay vì SMS.
- **Kiểm tra trạng thái xác thực:** Đảm bảo mọi yêu cầu nhạy cảm đều cần xác thực lại.
- **Thực hiện mã hóa mạnh mẽ:** Mã hóa thông tin nhạy cảm để bảo vệ chống lại các cuộc tấn công MitM.
- **Thực hiện bảo mật SMTP:** Không gửi thông tin nhạy cảm qua email, và sử dụng các liên kết khôi phục với token khó đoán.

7. Tham khảo

<https://portswigger.net/web-security/learning-paths/authentication-vulnerabilities>

<https://www.strongdm.com/blog/authentication-vulnerabilities>

<https://viblo.asia/s/authentication-vulnerability-lo-hong-xac-thuc-38X4EjZoJN2>

Mọi thắc mắc hay ý kiến đóng góp vui lòng liên hệ :

Email : r3dctf.info@gmail.com

@Design by R3D CTF Team